ZAP por Informe de Escaneo Checkmarx

Reporte PDF de Tienda MoAr

Sitio: http://localhost:8080

Generado a mié, 21 oct 2026 09:43:25

ZAP Versión: 2.17.0

ZAP by Checkmarx

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	2
Bajo	1
Informativo	1

Insights

Level	Razón	Site	Descripción	Statistic
Bajo	Advertencia		ZAP warnings logged - see the zap.log file for details	137
Información	Informativo	http://localhost:8080	Percentage of responses with status code 2xx	99 %
Información	Informativo	http://localhost:8080	Percentage of responses with status code 3xx	1 %
Información	Informativo	http://localhost:8080	Percentage of responses with status code 4xx	1 %
Información	Informativo	http://localhost:8080	Percentage of endpoints with content type application/json	35 %

Información	Informativo	http://localhost:8080	Percentage of endpoints with content type image /png	14 %
Información	Informativo	http://localhost:8080	Percentage of endpoints with content type text/css	14 %
Información	Informativo	http://localhost:8080	Percentage of endpoints with content type text /html	14 %
Información	Informativo	http://localhost:8080	Percentage of endpoints with content type text /javascript	21 %
Información	Informativo	http://localhost:8080	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:8080	Count of total endpoints	14
Información	Informativo	http://localhost:8080	Percentage of slow responses	27 %

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Cabecera Content Security Policy (CSP) no configurada	Medio	2
Librería JS Vulnerable	Medio	1
Divulgación de Marcas de Tiempo - Unix	Bajo	Systemic
Aplicación Web Moderna	Informativo	2

Detalles de la Alerta

Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.

URL	http://localhost:8080/swagger-ui.html
Nombre del Nodo	http://localhost:8080/swagger-ui.html
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:8080/swagger-ui/index.html
Nombre del Nodo	http://localhost:8080/swagger-ui/index.html
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	2
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	**Librería JS Vulnerable**
Descripción	La biblioteca identificada parece ser vulnerable.
URL	http://localhost:8080/swagger-ui/swagger-ui-bundle.js
Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-bundle.js
Método	GET
Ataque	
Evidencia	DOMPurify.version="3.1.6"
	La biblioteca identificada DOMPurify, versión 3.1.6, es vulnerable.CVE-2025-26791 CVE-2026-66010 CVE-2026-75838 CVE-2025-15599 CVE-2026-41239 CVE-2026-65899 CVE-2026-41238

Otra información	CVE-2026-65898 CVE-2026-109345 CVE-2026-65912 CVE-2026-65901 CVE-2026-65900 CVE-2026-65914 CVE-2026-65903 CVE-2026-65913 CVE-2026-65902 CVE-2026-0540 CVE-2026-41240 CVE-2026-49978 CVE-2026-49458 CVE-2026-49459 https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safeforxml https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safeforxml https://github.com/cure53/DOMPurify/security/advisories/GHSA-gvmj-g25r-r7wr https://github.com/cure53/DOMPurify/security/advisories/GHSA-c2j3-45gr-mqc4 https://github.com/cure53/DOMPurify/commit/d18ffcb554e0001748865da03ac75dd7829f0f02 https://github.com/cure53/DOMPurify/security/advisories/GHSA-cj63-jhhr-wcxv https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml https://github.com/cure53/DOMPurify/commit/fca0a938b4261ddc9c0293a289935a9029c049f5 https://github.com/cure53/DOMPurify/security/advisories/GHSA-39q2-94rc-95cp https://github.com/cure53/DOMPurify/commit/c861f5a83fb8d90800f1680f855fee551161ac2b https://github.com/cure53/DOMPurify/security/advisories/GHSA-r47g-fvhr-h676 https://github.com/cure53/DOMPurify/security/advisories/GHSA-h7mw-gpvr-xq4m https://github.com/cure53/DOMPurify/security/advisories/GHSA-cjmm-f4jc-qw8r https://github.com/cure53/DOMPurify/security/advisories/GHSA-cmwh-pvxp-8882 https://github.com/cure53/DOMPurify/pull/1537 https://github.com/cure53/DOMPurify/pull/1636 https://github.com/advisories/GHSA-vhxf-7vqr-mrjg

	https://github.com/cure53/DOMPurify/pull/1557 https://nvd.nist.gov/vuln/detail/CVE-2025-26791 https://ensy.zip/posts/dompurify-323-bypass https://nsysean.github.io/posts/dompurify-323-bypass https://github.com/cure53/DOMPurify/security/advisories/GHSA-rp9w-3fw7-7cwq https://github.com/cure53/DOMPurify/commit /b9b9d80f7e401771c2ccaef5f45def7eec8f27d7 https://github.com/cure53/DOMPurify/releases/tag/3.2.4 https://github.com/cure53/DOMPurify/releases/tag/3.3.2 https://github.com/cure53/DOMPurify/releases/tag/3.4.0 https://github.com/cure53/DOMPurify/releases/tag/3.4.16 https://github.com/cure53/DOMPurify/commit/3067f7746769 https://github.com/cure53/DOMPurify/security/advisories/GHSA-vxr8-fq34-vvx9 https://github.com/cure53/DOMPurify/security/advisories/GHSA-v9jr-rg53-9pgp https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safe-for-xml https://github.com/cure53/DOMPurify/security/advisories/GHSA-x4vx-rjvf-j5p4 https://github.com/cure53/DOMPurify/security/advisories/GHSA-hpcv-96wg-7vj8 https://github.com/cure53/DOMPurify/security/advisories/GHSA-h8r8-wccr-v5f2 https://github.com/cure53/DOMPurify https://github.com/cure53/DOMPurify/security/advisories/GHSA-55q2-fjhq-7xh7 https://github.com/cure53/DOMPurify/security/advisories/GHSA-6688-9rhm-gjv2 https://github.com/cure53/DOMPurify/releases/tag/3.4.12 https://github.com/cure53/DOMPurify/releases/tag/3.4.13 https://github.com/cure53/DOMPurify/commit /a9ca1e537422319a557a9a2aa61f003b23b4a197 https://github.com/cure53/DOMPurify/security/advisories/GHSA-crv5-9vww-q3g8 https://github.com/cure53/DOMPurify/security/advisories/GHSA-76mc-f452-cxcm
Instancia	1
Solución	Actualice a la versión más reciente de la biblioteca afectada.
Referencia	https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Bajo	**Divulgación de Marcas de Tiempo - Unix**
Descripción	Una marca de tiempo fue revelada por la aplicación/servidor web. - Unix
URL	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js

Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Método	GET
Ataque	
Evidencia	1518500249
Otra información	1518500249, que se evalúa como: 2018-02-13 02:37:29.
URL	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Método	GET
Ataque	
Evidencia	1732584193
Otra información	1732584193, que se evalúa como: 2024-11-25 22:23:13.
URL	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Método	GET
Ataque	
Evidencia	1750603025
Otra información	1750603025, que se evalúa como: 2025-06-22 10:37:05.
URL	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Método	GET
Ataque	
Evidencia	1859775393
Otra información	1859775393, que se evalúa como: 2028-12-07 01:16:33.
URL	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Nombre del Nodo	http://localhost:8080/swagger-ui/swagger-ui-standalone-preset.js
Método	GET
Ataque	
Evidencia	1894007588
Otra información	1894007588, que se evalúa como: 2030-01-07 06:13:08.
Instancia	Systemic
Solución	Confirmar que los datos encontrados de información sobre la marca de tiempo no son sensibles, ni se pueden usar en patrones explotables de divulgación.
Referencia	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Informativo	Aplicación Web Moderna
Descripción	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:8080/swagger-ui.html
Nombre del Nodo	http://localhost:8080/swagger-ui.html
Método	GET
Ataque	
Evidencia	<script src="./swagger-ui-bundle.js" charset="UTF-8"> </script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:8080/swagger-ui/index.html
Nombre del Nodo	http://localhost:8080/swagger-ui/index.html
Método	GET
Ataque	
Evidencia	<script src="./swagger-ui-bundle.js" charset="UTF-8"> </script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
Instancia	2
Solución	Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.
Referencia	
CWE Id	
WASC Id	
Plugin Id	10109